Entrega 3 · Documento 2

Resultados de pruebas de vulnerabilidades

Escaneo del servidor de aplicación y de las bases de datos

Sistema integrado de eventos laborales (JML)

Andina Servicios S.A.S. (empresa ficticia · datos ficticios)

Politécnico Grancolombiano · Gerencia de Proyectos en Seguridad de la Información · Grupo D01

24 de octubre de 2026

Todas las pruebas se ejecutaron contra el despliegue local del sistema (BunkerWeb + aplicación + PostgreSQL + GLPI 11 + MariaDB en Docker Compose). No se ejecutaron pruebas activas contra servicios de terceros (Supabase). Los secretos y tokens de las evidencias están enmascarados.

1. Resumen ejecutivo

Se evaluó la postura de seguridad del Sistema integrado de eventos laborales con escáneres de vulnerabilidades sobre el servidor de aplicación (Django tras el WAF BunkerWeb) y sobre las dos bases de datos (PostgreSQL de la aplicación y MariaDB de GLPI). Las pruebas se ejecutaron en dos posiciones: a través del WAF (defensa completa) y directamente contra la aplicación en la red interna (para medir el código sin el borde), según exige RS-13.

Resultado global: **sin vulnerabilidades explotables en la aplicación**. sqlmap con nivel 3 (incluidas las cabeceras) no halló inyección SQL ni con ni sin WAF; OWASP ZAP baseline no reportó ningún hallazgo de severidad FAIL; la configuración TLS no es vulnerable a ninguna de las 19 pruebas de testssl.sh; ningún servicio distinto de BunkerWeb publica puertos; y las bases de datos imponen en motor la inmutabilidad de la auditoría y las restricciones de permisos. Los hallazgos abiertos son de severidad media y baja y se refieren a mantenimiento de imágenes y a endurecimiento adicional, no a fallos explotables.

Herramienta	Objetivo	Resultado
nmap (-sV, -p-)	Host y redes internas app/db	Solo BunkerWeb expone 80/443; worker sin puertos
testssl.sh 3.2	TLS en app.localhost	TLS 1.2/1.3, AEAD+PFS; 0 vulnerabilidades
OWASP ZAP baseline	App con y sin WAF	0 FAIL (56/58 PASS); avisos informativos
sqlmap --level 3	Búsqueda de cuentas + cabeceras	No inyectable; WAF bloquea 1337 cargas (403)
Nikto	App con y sin WAF	Sin vulnerabilidades; solo notas de cabeceras
Trivy	Las 5 imágenes del stack	CVE de SO en imágenes base (ver §7)
Auditoría de BD	PostgreSQL y MariaDB	RLS, dueño separado e inmutabilidad verificados

2. Alcance y advertencia

Las pruebas se realizaron contra el despliegue local completo. **No se escaneó Supabase** (base y autenticación en la nube): es un servicio de terceros sin autorización para pruebas activas. Su PostgreSQL se sustituyó por una instancia local 17 con los mismos roles, el mismo esquema y el dueño separado (ADR-028), de modo que las pruebas de permisos, RLS e inmutabilidad son representativas. Las diferencias de configuración propias del entorno local (TLS, `pg_hba`) se señalan explícitamente en §8. La IP del escáner se excluyó del baneo del WAF durante las corridas para no interrumpir la medición.

Evidencia cruda: `evidencias/vulnerabilidades/` (salidas de nmap, testssl, ZAP en HTML y JSON, sqlmap, Nikto, Trivy y `bases-config.txt`). Guion de la auditoría de BD: `scripts/auditar-bases.sh`.

3. Superficie de red (nmap)

Se mapearon los 65 535 puertos TCP del host y de las dos redes internas de contenedores. En la red `app`, cada servicio expone solo su puerto de trabajo y el worker no expone ninguno; hacia el exterior solo responden el 80 y el 443 de BunkerWeb. Confirma RS-02 y la amenaza T19 (saltarse el WAF).

Host interno (red app)	Puertos abiertos	Servicio
bunkerweb (10.20.40.2)	8080, 8443, 5000	nginx/ModSecurity + API interna
web (10.20.40.3)	8000	Gunicorn (Django)
glpi (10.20.40.4)	80	Apache (GLPI)
worker (10.20.40.5)	— ninguno —	Cliente de GLPI; no escucha
postgres (red pg_net)	5432	PostgreSQL (red interna)
mariadb (red db_net)	3306	MariaDB (red interna, internal:true)

El único puerto inesperado es el 5000 de la API interna de BunkerWeb, visible en la red `app`. Se verificó que rechaza toda petición cerrando la conexión sin `API_TOKEN` (hallazgo V-03). Fuentes: `nmap-red-app.txt`, `nmap-postgres.txt`, `nmap-mariadb.txt`, `nmap-stack-expuesto.txt`.

4. Configuración TLS (testssl.sh)

El borde TLS de `app.localhost` ofrece solo TLS 1.2 y 1.3, con suites AEAD y secreto hacia adelante, intercambio de claves híbrido post-cuántico (X25519MLKEM768) y HSTS de un año. No es vulnerable a ninguna de las 19 pruebas (Heartbleed, ROBOT, CRIME, BREACH, POODLE, SWEET32, FREAK, DROWN, LOGJAM, BEAST, LUCKY13, RC4, etc.). Cumple RS-01.

Aspecto	Resultado
Protocolos	SSLv2/v3, TLS 1.0, TLS 1.1 no ofrecidos; TLS 1.2 y 1.3 sí
Suites de cifrado	Solo AEAD (AES-GCM, ChaCha20-Poly1305) con PFS
Intercambio de claves	ECDHE + X25519MLKEM768 (híbrido post-cuántico)
HSTS	max-age 31536000, includeSubDomains
Vulnerabilidades conocidas	0 de 19 (todas «not vulnerable»)

El certificado local es autofirmado (`CN=www.example.com`): esperado en desarrollo; en Azure lo emite Let's Encrypt (RS-01). Fuente: `testssl-app.txt`.

5. Pruebas de aplicación (ZAP, sqlmap, Nikto)

5.1 OWASP ZAP baseline

ZAP recorrió la aplicación autenticada como RRHH, a través del WAF y directamente contra Django. En ambas posiciones: **0 FAIL**. Los avisos restantes son informativos y explicables por el diseño.

Posición	FAIL	WARN	PASS	Avisos relevantes
A través del WAF	0	5	56	CSP ausente en una respuesta 302; ACAO:* en estáticos
Directo a Django (sin WAF)	0	3	58	nosniff ausente (lo añade el WAF); ACAO:* en estáticos

El aviso «CSP ausente» corresponde a una redirección 302 sin cuerpo; las páginas con contenido sí llevan la CSP estricta (verificado: `default-src 'self'; script-src 'self'; object-src 'none'; frame-ancestors 'none'`). El `nosniff` ausente en la posición directa lo añade BunkerWeb en el borde (RS-07), por eso no aparece con WAF. Fuentes: `zap-con-waf.json`, `zap-sin-waf.json`.

5.2 Inyección SQL (sqlmap, nivel 3, con cabeceras)

sqlmap probó la búsqueda de cuentas con cinco parámetros GET, la cookie de sesión y las cabeceras User-Agent y Referer, con `--level 3`. Ningún parámetro resultó inyectable. Contra el código directo, un falso positivo booleano en `usuario` se descartó en la propia verificación de sqlmap. A través del WAF, BunkerWeb respondió 403 a 1337 de las cargas. Cubre RS-13, T4.

Posición	Parámetros probados	Inyectables	Respuesta del WAF
Directo a Django	5 GET + cookie + UA + Referer	0	n/a
A través del WAF	GET + cookie + UA + Referer	0	403 × 1337 cargas, 429 × 1

La defensa de fondo es el ORM de Django con consultas parametrizadas (RS-05); el WAF es una capa adicional. Fuentes: `sqlmap-sin-waf.txt`, `sqlmap-con-waf.txt`.

5.3 Nikto

Nikto no encontró archivos peligrosos, rutas de administración expuestas ni cabeceras inseguras en ninguna de las dos posiciones. A través del WAF, los intentos de Nikto provocaron el baneo de la IP por «mal comportamiento», prueba de que `USE_BAD_BEHAVIOR` actúa (RS-08). Fuentes: `nikto-sin-waf.txt`, `nikto-con-waf.txt`.

6. Configuración de las bases de datos

La auditoría de configuración confirmó los controles de datos del SRS en el motor, no solo en el código. Se ejecutaron pruebas negativas dentro de transacciones revertidas.

Control (PostgreSQL)	Esperado	Verificado
Dueño de las tablas (ADR-028)	app_owner, no app_backend	Sí, las 26 tablas
app_backend sobre auditoría	Solo INSERT/SELECT (RD-02)	Sí; UPDATE/DELETE denegados
Inmutabilidad de solicitud aprobada	Disparador la bloquea (RF-14)	Sí; UPDATE rechazado por el disparador
Transición de estado inválida	Disparador la bloquea	Sí; en_ejecución→pendiente rechazada
RLS en tablas del esquema app	Activo	Sí (app_backend con BYPASSRLS, sin políticas)
Permisos a PUBLIC en esquema app	Ninguno	Sí; 0 grants
Roles anon / authenticated	Sin login, sin privilegios	Sí; no pueden iniciar sesión

MariaDB (base de GLPI, red `db_net` interna): el usuario `glpi` tiene privilegios solo sobre la base `glpi`; `skip_name_resolve` activo. Quedan como endurecimiento `local_infile=ON` y `require_secure_transport=OFF` (hallazgo V-04). Fuente: `bases-config.txt`.

7. Vulnerabilidades de imágenes (Trivy)

Trivy analizó las cinco imágenes (severidad alta y crítica). La aplicación propia (`jml-app`) se escaneó desde el sistema de archivos del contenedor porque el almacén local de Docker no entregó una de sus capas comprimidas; el resultado es equivalente. Los hallazgos son CVE del sistema operativo base y de bibliotecas de terceros, no del código del proyecto.

Imagen	Crítica	Alta	Observación
jml-app (aplicación)	1	44	certifi (con parche); SO Debian sin parche disponible
BunkerWeb 1.6.15	1	24	Alpine; todas con parche en imagen superior
GLPI 11.0.11	13	277	libs cliente MariaDB, libxml2, kernel-headers (Debian)
PostgreSQL 17	2	86	gosu (Go stdlib, con parche); libxml2 (SO)
MariaDB 11.4	1	25	gosu (Go stdlib, con parche)

Las imágenes están fijadas por digest (RS-18), lo que da reproducibilidad pero congela el SO: las actualizaciones de seguridad exigen refrescar el digest. En la CI, Trivy ya corre antes de publicar la imagen de la aplicación y pip-audit/bandit sobre el código (RS-11). Fuente: `trivy/*.json` y `trivy/*.txt`.

8. Hallazgos

Cada hallazgo incluye severidad, evidencia, impacto, corrección y un indicador para detectar en producción si la corrección falla (chequeo de falsabilidad).

V-01 · Imágenes base con CVE de SO conocidos	Media
Evidencia	Trivy: GLPI 13 críticas / 276 altas; PostgreSQL 1 crítica; gosu con parche en postgres y mariadb (trivy/*.json).
Impacto	CVE de bibliotecas del sistema en imágenes de terceros; la mayoría sin ruta de explotación directa en este despliegue, pero RS-11 exige que una crítica no llegue a producción.
Corrección	Refrescar los digest de las imágenes de terceros en cada ventana de mantenimiento y volver a correr Trivy; mantener la compuerta de Trivy en la CI que bloquea críticas de la imagen propia.
Falsabilidad	Un informe de Trivy programado con una crítica nueva y explotable no atendida en 30 días es la señal de que la cadencia falló.

V-02 · Avisos de cabeceras en respuestas sin cuerpo	Baja
Evidencia	ZAP: «CSP ausente» en un 302; «ACAO:*» en archivos estáticos (zap-con-waf.json).
Impacto	Las redirecciones sin cuerpo no ejecutan contenido; los estáticos no portan datos sensibles. Riesgo real bajo.
Corrección	Opcional: emitir la CSP también en las redirecciones y restringir Access-Control-Allow-Origin de los estáticos servidos por WhiteNoise.
Falsabilidad	Una página con cuerpo que respondiera sin CSP estricta aparecería como FAIL en el ZAP de la CI.

V-03 · API interna de BunkerWeb visible en la red app	Baja
Evidencia	nmap: puerto 5000 abierto en 10.20.40.2 (red app). Prueba activa: rechaza sin API_TOKEN cerrando la conexión (bunkerweb-api-desde-red-app.txt).
Impacto	La API no queda estrictamente aislada en bw-universe como sugiere RS-19, pero el token y la lista blanca de IP la protegen (defensa en profundidad).
Corrección	Confirmar que la IP de la red app no está en API_WHITELIST_IP (hoy 127.0.0.0/8 y 10.20.30.0/24) y, si el diseño lo permite, separar la interfaz de red de la API.
Falsabilidad	Una petición a http://10.20.40.2:5000/instances que devuelva 200 sin token indicaría que la protección se perdió.

V-04 · Endurecimiento adicional de MariaDB	Baja
Evidencia	bases-config.txt: local_infile=ON, require_secure_transport=OFF en MariaDB.
Impacto	Bajo: MariaDB solo es accesible por la red interna db_net (internal:true) y solo por GLPI. Sin exposición externa.
Corrección	Desactivar local_infile si GLPI no lo requiere y exigir TLS en el tramo GLPI↔MariaDB dentro del host.
Falsabilidad	Un nmap que mostrara el 3306 fuera de db_net, o un LOAD DATA LOCAL exitoso, revelaría regresión.

V-05 · Configuración TLS/pg_hba del PostgreSQL local	Informativa
Evidencia	bases-config.txt: ssl=off y pg_hba con «trust» para conexiones locales en el contenedor PostgreSQL de desarrollo.
Impacto	Solo afecta al entorno local de pruebas; en producción la base es Supabase, que exige TLS (verify-full) y autenticación scram.
Corrección	Ninguna en producción. Para el entorno local, documentar que no reproduce el TLS de Supabase; opcionalmente activar ssl en el contenedor.
Falsabilidad	La aplicación en Azure que se conectara a Supabase sin verify-full (revisable en los ajustes) sería la regresión a vigilar.

9. Conclusión

La aplicación resistió las pruebas activas: sin inyección SQL, sin hallazgos FAIL de ZAP, sin vulnerabilidades TLS y sin servicios expuestos más allá del WAF. Las bases de datos imponen en el motor la inmutabilidad y los permisos mínimos. Los cinco hallazgos son de severidad media o inferior y apuntan a mantenimiento de imágenes y endurecimiento, no a defectos explotables. Se recomienda atender V-01 (cadencia de actualización de imágenes) como prioridad y completar, en Azure, las pruebas dinámicas sobre el despliegue real (pendiente de RS-13 contra producción).